

THREAT MODELING

Hasil Vulnerability Assessment Awal

Bacarita

*Platform Pembelajaran Membaca Adaptif Berbasis Web
Terintegrasi AI Eye-Tracking untuk Anak Disleksia*

Metodologi: STRIDE + OWASP Top 10 (2021)

Metode: Static Application Security Testing (SAST) — Source Code Review

Status: Assessment Awal (Pre-production)

Daftar Isi

1. Ringkasan Eksekutif	3
2. Konteks Keamanan	3
2.1. Kekhususan Konteks: Data Anak Disleksia	3
2.2. Aliran Data Utama	4
2.3. Aktor Ancaman	5
3. Analisis STRIDE	5
3.1. Metodologi	5
3.2. Analisis per Komponen	6
3.2.1. Modul Autentikasi	6
3.2.2. Modul Guard dan Otorisasi	6
3.2.3. Data Kognitif Anak (Eye-Tracking & ASR)	6
3.2.4. Manajemen Konten (Cerita Berlevel)	7
3.2.5. Integrasi AI	8
4. Vulnerability Assessment Awal	8
4.1. Temuan Detail	8
4.1.1. [VA-01] Token JWT Tersimpan Plain-Text di Database — KRITIS	8
4.1.2. [VA-02] Data Kognitif Anak Tanpa Enkripsi At-Rest — KRITIS	8
4.1.3. [VA-03] Tidak Ada Rate Limiting pada Endpoint Login — TINGGI	9
4.1.4. [VA-04] Cookie Token Tanpa Flag HttpOnly dan Secure — TINGGI	9
4.1.5. [VA-05] Tidak Ada Account Lockout — TINGGI	10
4.1.6. [VA-06] Konten Cerita Dikirim ke LLM Eksternal Tanpa Anonimisasi — SEDANG	10
4.1.7. [VA-07] Tidak Ada Refresh Token — SEDANG	10
4.1.8. [VA-08] Validasi Password Lemah — SEDANG	10
4.1.9. [VA-09] Inkonsistensi Pesan Error Login — RENDAH	11
5. Matriks Risiko	11
5.1. Prioritas Remediasi	13
6. Rekomendasi Implementasi	14
6.1. Jangka Pendek	14
6.1.1. Rate Limiting	14
6.1.2. HttpOnly Cookie via Next.js	14
6.1.3. Validasi Password	14
6.2. Jangka Menengah	14
6.2.1. Hash Token di Database	14
6.2.2. Audit Log Autentikasi	14
6.2.3. Kebijakan Privasi Data Kognitif Anak	15
7. Kesimpulan	15

1. Ringkasan Eksekutif

Dokumen ini menyajikan hasil **threat modeling** dan **vulnerability assessment** awal terhadap sistem Bacarita—platform pembelajaran membaca berbasis AI yang secara khusus melayani anak-anak dengan disleksia. Terdapat pertimbangan keamanan dan privasi khusus dalam sistem ini karena:

- Pengguna utama adalah anak di bawah umur dengan kondisi disabilitas belajar spesifik
- Sistem mengumpulkan data perilaku kognitif sensitif: pola gerakan mata, rekaman suara anak, dan pola kesalahan fonologis
- Data eye-tracking dapat mengungkap kondisi neurologis anak secara tidak langsung — termasuk dalam kategori data kesehatan
- Terdapat relasi data anak (siswa) dengan wali (orang tua) dan pendidik (guru) yang perlu dilindungi secara ketat

Assessment menemukan **9 temuan kerentanan** dengan distribusi:

Tingkat Risiko	Jumlah	Contoh Temuan
Kritis	2	Token JWT plain-text di database; data kognitif anak tanpa enkripsi at-rest
Tinggi	4	Tidak ada rate limiting, cookie tanpa HttpOnly, tidak ada account lockout, API key AI tanpa rotasi
Sedang	2	Tidak ada refresh token, validasi password lemah
Rendah	1	Inkonsistensi pesan error login

Tabel 1: Ringkasan temuan vulnerability assessment

Rekomendasi utama: Prioritaskan proteksi data kognitif anak (enkripsi at-rest, kebijakan retensi audio STT), kemudian terapkan HttpOnly cookie dan rate limiting pada endpoint login.

2. Konteks Keamanan

2.1. Kekhususan Konteks: Data Anak Disleksia

Bacarita memproses tiga kategori data anak yang tidak umum dijumpai pada aplikasi web biasa:

Kategori Data	Sumber	Sensitivitas
Pola gerakan mata	MediaPipe Face Mesh di browser; event dikirim ke tabel <code>distraction_eye_events</code>	Sangat Tinggi
Rekaman suara anak	Web Speech API / ASR; hasil kata disimpan di <code>stt_word_results</code>	Sangat Tinggi
Pola kesalahan fonologis	Hasil ASR per kata: kata yang disubstitusi, dilewati, atau salah ucap	Tinggi
Kondisi konsentrasi	Frekuensi dan durasi distraksi yang mencerminkan kondisi kognitif	Tinggi

Tabel 2: Kategori data sensitif anak yang diproses Bacarita

Data di atas memiliki implikasi privasi yang jauh lebih dalam dibandingkan data pengguna biasa karena secara tidak langsung mengungkapkan kondisi neurologis/kesehatan anak penyandang disleksia.

2.2. Aliran Data Utama

Aliran	Deskripsi	Protokol
Browser → MediaPipe	Model ML dieksekusi lokal di browser; gaze data diproses di sisi klien	In-browser
Browser → Backend	Event distraksi (frekuensi, jenis) dikirim via Axios; Bearer JWT di Authorization header	HTTPS
Browser → ASR	Audio rekaman anak → transkripsi teks	HTTPS / Local
Backend → MySQL	TypeORM queries; koneksi lokal atau jaringan privat	TCP
Backend → OpenAI/OpenRouter	Teks konten cerita dikirim ke LLM untuk generasi kalimat latihan	HTTPS
Backend → SMTP	Email notifikasi ke guru dan orang tua	SMTP/TLS
Token di Browser	JWT disimpan di cookie via <code>js-cookie</code> tanpa opsi keamanan eksplisit	—

Tabel 3: Aliran data utama sistem Bacarita

2.3. Aktor Ancaman

Aktor	Motivasi dan Kapabilitas	Kemungkinan
Penyerang data anak	Mencuri profil siswa disleksia dan data kognitif untuk penyalahgunaan atau penjualan	Sedang
Bot / Otomatis	Credential stuffing, brute force login akun guru atau orang tua	Tinggi
Pengguna internal nakal	Guru mengakses data siswa di luar kelasnya; kurator mengakses data sesi	Sedang
Penyerang MitM	Intersepsi komunikasi browser → backend jika HTTPS tidak dikonfigurasi	Sedang
Script injection (XSS)	Eksfiltrasi token JWT dari cookie yang tidak di-protect HttpOnly	Tinggi
Manipulator konten	Menyuntikkan cerita yang tidak sesuai prinsip disleksia sebelum dikurasi	Rendah

Tabel 4: Profil aktor ancaman

3. Analisis STRIDE

3.1. Metodologi

Huruf	Kategori	Deskripsi
S	Spoofing	Menyamar sebagai entitas lain yang sah
T	Tampering	Modifikasi data atau kode secara tidak sah
R	Repudiation	Menyangkal telah melakukan suatu tindakan
I	Information Disclosure	Eksposur informasi yang seharusnya rahasia
D	Denial of Service	Mengganggu ketersediaan layanan
E	Elevation of Privilege	Mendapatkan hak akses melebihi yang diberikan

Tabel 5: Kategori ancaman STRIDE

3.2. Analisis per Komponen

3.2.1. Modul Autentikasi

ID	STRIDE	Ancaman	Risiko
AUTH-01	S	Credential stuffing terhadap akun guru dan orang tua; tidak ada rate limiting pada endpoint login	Tinggi
AUTH-02	S	Brute force username/password siswa; endpoint /auth/students/login tidak dilindungi throttle	Tinggi
AUTH-03	I	Token JWT aktif tersimpan plain-text di kolom token TEXT NULL pada seluruh tabel pengguna	Kritis
AUTH-04	E	Role dikodekan dalam JWT payload; jika JWT secret lemah atau bocor, penyerang dapat memalsukan peran admin	Tinggi
AUTH-05	T	Cookie token disimpan tanpa flag HttpOnly dan Secure; rentan terhadap pencurian via XSS	Tinggi
AUTH-06	R	Tidak ada audit log untuk kejadian login gagal; penyangkalan aktivitas akun tidak dapat dibuktikan	Sedang
AUTH-07	D	Tidak ada rate limiting; endpoint login dapat dibanjiri untuk exhausting koneksi database	Sedang

Tabel 6: Analisis STRIDE modul autentikasi

3.2.2. Modul Guard dan Otorisasi

ID	STRIDE	Ancaman	Risiko
GUARD-01	E	Role hanya diperiksa dari JWT payload; tidak diverifikasi ulang ke database; token belum di-revoke tetap valid hingga kadaluarsa	Sedang
GUARD-02	S	Jika JWT secret bocor dari .env, seluruh mekanisme autentikasi semua peran dapat dikompromikan sekaligus	Kritis
GUARD-03	E	Tidak ada refresh token; access token berumur panjang memperbesar window of exposure jika token dicuri	Sedang

Tabel 7: Analisis STRIDE guard dan otorisasi

3.2.3. Data Kognitif Anak (*Eye-Tracking & ASR*)

Ini adalah komponen dengan implikasi privasi terbesar dalam sistem Bacarita:

ID	STRIDE	Ancaman	Risiko
COG-01	I	Data eye-tracking (<code>distraction_eye_events</code>) dan STT (<code>stt_word_results</code>) tersimpan tanpa enkripsi at-rest di MySQL; mengungkapkan kondisi kognitif anak disleksia	Kritis
COG-02	I	Konten cerita yang dibaca anak dikirim ke LLM eksternal (OpenAI/OpenRouter) tanpa anonimisasi konteks siswa	Sedang
COG-03	T	Tidak ada validasi integritas pada data event eye-tracking yang dikirim dari browser; data dapat dimanipulasi untuk memalsukan skor AD	Sedang
COG-04	I	Rekaman audio anak (komponen ASR) — jika disimpan sebelum diproses — tidak ada kebijakan retensi dan penghapusan yang terdokumentasi	Tinggi
COG-05	R	Tidak ada mekanisme untuk siswa/orang tua melihat, mengunduh, atau meminta penghapusan data kognitif mereka (hak subjek data)	Sedang

Tabel 8: Ancaman pada data kognitif anak

3.2.4. Manajemen Konten (Cerita Berlevel)

ID	STRIDE	Ancaman	Risiko
CONT-01	T	Konten cerita yang tidak sesuai prinsip disleksia dapat diunggah admin sebelum dikurasi; alur kurasi melindungi tetapi tidak sempurna	Rendah
FILE-01	T	Upload file gambar cerita via Multer; validasi MIME type dan batas ukuran tidak terkonfirmasi dari review awal	Sedang
FILE-02	I	Path file gambar tersimpan langsung di kolom <code>image VARCHAR(255)</code> ; potensi path traversal jika path tidak disanitasi	Sedang

Tabel 9: Ancaman pada manajemen konten

3.2.5. Integrasi AI

ID	STRIDE	Ancaman	Risiko
AI-01	I	API Key OpenAI/OpenRouter disimpan di environment variable; jika .env terekspos, kredensial bocor dan dapat disalahgunakan dengan biaya besar	Kritis
AI-02	T	Prompt injection: teks cerita yang dikirim ke LLM tidak disanitasi; konten berbahaya dapat memanipulasi output kalimat latihan	Sedang
AI-03	D	Tidak ada circuit breaker pada panggilan AI eksternal; kegagalan layanan dapat menyebabkan timeout massal pada sesi Baca Lancar	Rendah

Tabel 10: Ancaman pada integrasi AI

4. Vulnerability Assessment Awal

4.1. Temuan Detail

4.1.1. [VA-01] Token JWT Tersimpan Plain-Text di Database — KRITIS

Kategori OWASP: A02:2021 — Cryptographic Failures

Bukti teknis (migrasi TypeORM):

```
-- Berlaku untuk semua tabel: teachers, students, parents, admins, curators  
'token' text NULL
```

Bukti teknis (auth.service.ts):

```
const token: string = this.generateJwtToken(currentUser);  
teacher.token = token; // JWT disimpan langsung ke entity  
await this.teacherService.save(teacher);
```

Dampak: Jika database dikompromikan, seluruh session aktif semua pengguna (termasuk akun guru dan orang tua yang memiliki akses ke data kognitif anak) dapat langsung digunakan oleh penyerang tanpa mengetahui password.

Rekomendasi: Simpan hash SHA-256 dari token sebagai pengganti token asli. Guard hanya perlu mencocokkan hash dari token di request dengan hash di database.

—

4.1.2. [VA-02] Data Kognitif Anak Tanpa Enkripsi At-Rest — KRITIS

Kategori OWASP: A02:2021 — Cryptographic Failures; A01:2021 — Broken Access Control

Bukti teknis (migrasi):


```
CREATE TABLE `distraction_eye_events` (...)
-- Kolom: frekuensi distraksi, jenis distraksi, durasi, timestamp
-- Tidak ada enkripsi; data disimpan plain-text

CREATE TABLE `stt_word_results` (...)
-- Kolom: kata yang diucapkan, kata acuan, skor akurasi per kata
-- Mengungkap pola fonologis spesifik kesalahan anak disleksia
```

Dampak: Data pola kognitif anak disleksia (kondisi kesehatan/neurologis) terekspos jika database dikompromikan. Ini termasuk data kesehatan anak di bawah umur yang memiliki perlindungan hukum lebih ketat.

Rekomendasi: Aktifkan enkripsi at-rest di level MySQL (Transparent Data Encryption) atau enkripsi kolom sensitif di level aplikasi sebelum menyimpan ke database.

4.1.3. [VA-03] Tidak Ada Rate Limiting pada Endpoint Login — TINGGI

Kategori OWASP: A07:2021 — Identification and Authentication Failures

Bukti teknis (auth.controller.ts):

```
@Post('teachers/login')
@HttpCode(200)
public async loginTeacher(
  @Body() teacherSignInDto: TeacherSignInDTO,
): Promise<DataResponse<ITokenResponse>> { ... }
// Tidak ada @UseGuards(ThrottlerGuard) atau dekorator rate limiting
```

Tidak ditemukan penggunaan @nestjs/throttler di seluruh modul autentikasi.

Dampak khusus Bacarita: Akun siswa menggunakan username sederhana (bukan email) — format yang lebih mudah ditebak — sehingga lebih rentan terhadap brute force.

Rekomendasi: Pasang @nestjs/throttler dengan konfigurasi ketat (misalnya TTL=60s, limit=5) per IP pada semua endpoint login.

4.1.4. [VA-04] Cookie Token Tanpa Flag HttpOnly dan Secure — TINGGI

Kategori OWASP: A05:2021 — Security Misconfiguration

Bukti teknis (auth.services.tsx frontend):

```
Cookies.set("token", token);
// Tidak ada: { httpOnly: true, secure: true, sameSite: 'strict' }
```

js-cookie di browser tidak dapat menyetel flag HttpOnly (hanya bisa dari server). Token yang ada di cookie JavaScript-accessible mudah dicuri oleh XSS.

Dampak khusus Bacarita: Jika halaman siswa rentan XSS, token anak dapat dicuri, memberikan akses ke data sesi baca dan data kognitif.

Rekomendasi: Pindahkan pengelolaan token ke cookie server-side yang diset oleh Next.js API route dengan HttpOnly; Secure; SameSite=Strict.

4.1.5. [VA-05] *Tidak Ada Account Lockout* — **TINGGI**

Kategori OWASP: A07:2021 — Identification and Authentication Failures

Bukti teknis: Tidak ada kolom `failedLoginAttempts` atau `lockedUntil` pada entitas manapun (dikonfirmasi dari seluruh migrasi).

Rekomendasi: Tambahkan kolom `failedLoginAttempts` INT DEFAULT 0 dan `lockedUntil` DATETIME NULL; kunci akun sementara setelah 5 kali gagal.

4.1.6. [VA-06] *Konten Cerita Dikirim ke LLM Eksternal Tanpa Anonimisasi* — **SEDANG**

Kategori OWASP: A02:2021 — Cryptographic Failures; Privasi Data

Konteks: Fitur Baca Lancar menggunakan LLM (OpenAI/OpenRouter) untuk menghasilkan kalimat latihan berdasarkan konten cerita yang baru dibaca siswa.

Risiko: Jika request ke LLM menyertakan konteks siswa (nama, ID, atau data sesi), data anak dikirim ke layanan pihak ketiga.

Rekomendasi: Pastikan payload ke LLM hanya berisi teks konten cerita, tanpa identifier siswa. Tinjau DPA (Data Processing Agreement) dengan OpenAI/OpenRouter terkait data anak.

4.1.7. [VA-07] *Tidak Ada Refresh Token* — **SEDANG**

Kategori OWASP: A07:2021 — Identification and Authentication Failures

Bukti teknis (auth.service.ts):

```
public generateJwtToken(user: ICurrentUser): string {
    return this.jwtService.sign(user);
    // Tidak ada expiresIn; tidak ada access + refresh token separation
}
```

Rekomendasi: Konfigurasi `expiresIn` eksplisit (misal 1 jam untuk access token). Implementasikan refresh token berumur lebih panjang yang disimpan di HttpOnly cookie.

4.1.8. [VA-08] *Validasi Password Lemah* — **SEDANG**

Kategori OWASP: A07:2021 — Identification and Authentication Failures

Bukti teknis (student-sign-in.dto.ts):

```
@IsNotEmpty({ message: 'Username tidak boleh kosong' })
@IsString()
username: string;

@IsNotEmpty({ message: 'Password tidak boleh kosong' })
@IsString()
password: string;
// Tidak ada @MinLength, @MaxLength, atau @Matches untuk kompleksitas
```

Rekomendasi: Tambahkan minimal `@MinLength(8)` pada semua DTO login dan registrasi.

4.1.9. [VA-09] Inkonsistensi Pesan Error Login — RENDAH

Kategori OWASP: A09:2021 — Security Logging and Monitoring Failures

Bukti teknis (auth.service.ts):

```
// loginStudent - pesan spesifik
throw new UnauthorizedException('Kredensial salah');

// loginTeacher - tanpa pesan
if (!teacher) throw new UnauthorizedException();
```

Rekomendasi: Standarisasi semua error autentikasi menjadi pesan generik tunggal.

5. Matriks Risiko

Risiko = Kemungkinan $\times$ Dampak (skala 1–5).

ID	Kemungkinan	Dampak	Skor	Level	Judul
AUTH-03	4	5	20	Kritis	Token JWT plain-text di DB
COG-01	3	5	15	Kritis	Data kognitif anak tanpa enkripsi at-rest
AUTH-01	5	4	20	Kritis	Credential stuffing (no rate limit)
AUTH-05	4	5	20	Kritis	Cookie tanpa HttpOnly/Secure
AUTH-02	4	4	16	Tinggi	Brute force login siswa
USER-03	4	4	16	Tinggi	Tidak ada account lockout
COG-04	3	4	12	Tinggi	Rekaman audio anak tanpa kebijakan retensi
AI-01	2	5	10	Tinggi	API Key AI bocor dari .env
GUARD-03	3	3	9	Sedang	Tidak ada refresh token
COG-02	3	3	9	Sedang	Konten cerita dikirim ke LLM tanpa anonimisasi
COG-03	2	4	8	Sedang	Manipulasi data eye-tracking untuk memalsukan skor AD
AUTH-04	2	5	10	Tinggi	Role spoofing via JWT secret lemah
FILE-01	2	4	8	Sedang	Upload file tanpa validasi MIME
VA-08	3	3	9	Sedang	Password lemah siswa
AUTH-06	3	2	6	Sedang	Tidak ada audit log
VA-09	2	2	4	Rendah	Inkonsistensi pesan error

Tabel 11: Matriks risiko semua temuan

5.1. Prioritas Remediasi

Prioritas	ID	Tindakan	Effort
P1	AUTH-05	Pindah token ke HttpOnly server-side cookie (Next.js API route)	Sedang
P1	AUTH-01/02	Pasang <code>@nestjs/throttler</code> pada semua endpoint login	Rendah
P1	USER-03	Implementasikan account logout (kolom <code>failedLoginAttempts</code>)	Sedang
P2	AUTH-03	Simpan hash SHA-256 token di DB; bukan token asli	Sedang
P2	COG-01	Aktifkan enkripsi at-rest MySQL TDE atau enkripsi kolom kognitif di aplikasi	Tinggi
P2	COG-04	Tentukan kebijakan retensi dan penghapusan data audio/STT; dokumentasikan	Rendah
P3	GUARD-03	Implementasikan access + refresh token dengan <code>expiresIn</code> eksplisit	Tinggi
P3	COG-02	Audit payload yang dikirim ke LLM; pastikan tidak menyertakan identifier siswa	Rendah
P3	VA-08	Tambahkan <code>@MinLength(8)</code> dan validasi kompleksitas di semua DTO auth	Rendah
P4	AI-01	Pastikan <code>.env</code> di <code>.gitignore</code> ; rotasi API key berkala; gunakan secret manager	Rendah
P4	COG-03	Tambahkan validasi dan tanda tangan pada payload event eye-tracking dari frontend	Sedang
P4	FILE-01	Konfigurasi whitelist MIME type dan batas ukuran di Multer	Rendah
P4	COG-05	Implementasikan endpoint hak subjek data (lihat/hapus data kognitif) untuk siswa/orang tua	Tinggi

Tabel 12: Prioritas remediasi

6. Rekomendasi Implementasi

6.1. Jangka Pendek

6.1.1. Rate Limiting

```
// app.module.ts
import { ThrottlerModule, ThrottlerGuard } from '@nestjs/throttler';
imports: [
  ThrottlerModule.forRoot([
    { ttl: 60000, limit: 5 }
  ]),
]

// auth.controller.ts
@UseGuards(ThrottlerGuard)
@Post('students/login')
async loginStudent(...) { ... }
```

6.1.2. HttpOnly Cookie via Next.js

```
// pages/api/auth/set-session.ts
res.setHeader('Set-Cookie',
  `token=${token}; HttpOnly; Secure; SameSite=Strict; Path=/; Max-Age=3600`
);
// Hapus: Cookies.set("token", token) di client-side
```

6.1.3. Validasi Password

```
import { MinLength } from 'class-validator';

@MinLength(8, { message: 'Password minimal 8 karakter' })
@IsString()
@NotEmpty()
password: string;
```

6.2. Jangka Menengah

6.2.1. Hash Token di Database

```
import { createHash } from 'crypto';

// Saat login - simpan hash, bukan token asli:
const tokenHash = createHash('sha256').update(token).digest('hex');
teacher.token = tokenHash;

// Di guard - bandingkan hash:
const incoming = createHash('sha256').update(token).digest('hex');
const user = await repo.findOne({ where: { token: incoming } });
```

6.2.2. Audit Log Autentikasi

```
CREATE TABLE `auth_audit_logs` (
  `id` int NOT NULL AUTO_INCREMENT,
  `userId` varchar(255) NOT NULL,
  `role` varchar(50) NOT NULL,
```

```

`event` enum('LOGIN_SUCCESS','LOGIN_FAIL','LOGOUT') NOT NULL,
`ipAddress` varchar(45) NULL,
`createdAt` datetime(6) NOT NULL DEFAULT CURRENT_TIMESTAMP(6),
PRIMARY KEY (`id`)
) ENGINE=InnoDB;

```

6.2.3. Kebijakan Privasi Data Kognitif Anak

Sebelum deployment produksi, dokumentasikan dan implementasikan:

- **Retensi:** tentukan berapa lama data `distraction_eye_events` dan `stt_word_results` disimpan
- **Penghapusan:** implementasikan endpoint untuk menghapus data sesi anak atas permintaan orang tua
- **Minimisasi:** kirim ke LLM hanya teks cerita tanpa ID siswa, nama, atau metadata sesi
- **Transparansi:** tampilkan kepada orang tua data apa yang dikumpulkan dan bagaimana penggunaannya
- **DPA:** pastikan Data Processing Agreement dengan OpenAI/OpenRouter mencakup perlindungan data anak

7. Kesimpulan

Bacarita memiliki fondasi keamanan yang baik—bcrypt untuk password, RBAC berbasis dekorator yang konsisten, validasi input dengan `class-validator`, dan mekanisme logout server-side melalui invalidasi token di database. Namun, konteks penggunaan platform ini secara signifikan meninggikan standar keamanan dan privasi yang harus dipenuhi dibandingkan aplikasi web umum.

Sistem Bacarita mengumpulkan data yang dapat dikategorikan sebagai data kesehatan anak di bawah umur: pola gerakan mata yang merepresentasikan kondisi neurologis disleksia, rekaman suara anak, dan pola kesalahan fonologis yang bersifat diagnostik. Eksposur data ini—baik melalui token yang tidak terlindungi, database yang tidak terenkripsi, atau transmisi ke layanan AI pihak ketiga—memiliki implikasi hukum, etika, dan kepercayaan yang jauh lebih besar dari kerentanan tipikal.

Prioritas remediasi seharusnya mencerminkan kekhususan ini: selain hardening autentikasi standar, tim pengembang perlu mendefinisikan kebijakan privasi data kognitif anak, mengimplementasikan enkripsi at-rest, dan memastikan kepatuhan DPA terhadap layanan AI eksternal—sebelum platform ini digunakan secara luas di sekolah.